

# NIST Cybersecurity Framework (CSF) Risk Assessment Report

*Asset Inventory, Threat Identification, Risk Rating Matrix & Risk Treatment Plan*

**Meridian Diagnostics Pvt. Ltd. (fictional organization)**

Prepared by: Nivedhitha K.S. (Crystal)

Document Classification: Confidential — Internal Use Only

Version: 1.0 | Date: June 2026

## 1. Document Control

| Field               | Detail                                                                                                   |
|---------------------|----------------------------------------------------------------------------------------------------------|
| Document Title      | NIST CSF Risk Assessment — Asset Inventory, Threat Identification, Risk Rating, Treatment Plan           |
| Organization        | Meridian Diagnostics Pvt. Ltd. (fictional organization)                                                  |
| Framework Reference | NIST Cybersecurity Framework (CSF) v2.0 — Functions: Govern, Identify, Protect, Detect, Respond, Recover |
| Author              | Nivedhitha K.S. (Crystal) — GRC Analyst (Portfolio Project)                                              |
| Version             | 1.0                                                                                                      |
| Status              | Final — Draft for Review                                                                                 |
| Review Cycle        | Annual, or upon significant change to systems, threat landscape, or business operations                  |
| Classification      | Confidential — Internal Use Only                                                                         |

## 2. Executive Summary

This report presents a structured cybersecurity risk assessment for Meridian Diagnostics Pvt. Ltd., aligned to the NIST Cybersecurity Framework (CSF) v2.0. The assessment identifies critical information assets, maps relevant threat sources and threat events against those assets, evaluates the resulting risks using a 5x5 likelihood-impact matrix, and proposes a prioritized risk treatment plan with controls mapped to specific NIST CSF subcategories.

The assessment identified 15 critical assets spanning clinical applications, cloud infrastructure, identity systems, and third-party integrations. Twelve distinct threat scenarios were evaluated against these assets, producing 12 discrete risks in the risk register. Of these, two risks — ransomware deployment against core clinical systems (R-01) and phishing-driven compromise of the patient records database (R-02) — were rated Critical and require immediate treatment. A further five risks were rated High, with the remainder rated Medium.

The treatment plan prioritizes Identify and Protect function controls (access management, segmentation, MFA, and cloud security posture management) within the first 0-6 months, supported by Detect function enhancements (EDR, UEBA, wireless intrusion detection) and Recover function improvements (backup validation, BCP/DR testing) over a 9-month horizon. This phased approach reflects a risk-based prioritization consistent with the organization's available resources and operational constraints.

## 3. Scope and Methodology

### 3.1 Scope

This assessment covers information systems, applications, infrastructure, and third-party integrations that support core clinical and administrative operations, including patient records management, hospital information systems, cloud-hosted patient portal and billing services,

identity and access management infrastructure, endpoint devices, and connected medical/diagnostic devices across six facility sites.

*The organization, asset names, and figures used throughout this report are illustrative/fictional and have been constructed for portfolio demonstration purposes. The methodology, control mappings, and structure are directly applicable to real-world NIST CSF-based risk assessments.*

## 3.2 Methodology

The assessment was performed using the following sequential approach, consistent with NIST CSF guidance and NIST SP 800-30 (Guide for Conducting Risk Assessments):

- **Asset Inventory:** Identified and categorized information assets, assigning ownership and a Confidentiality-Integrity-Availability (CIA) criticality rating (High / Medium / Low) to each.
- **Threat Identification:** Identified relevant threat sources (external, internal, environmental) and associated threat events, each mapped to the vulnerabilities they would exploit.
- **Risk Rating:** Combined likelihood (probability of threat event occurring, scale 1-5) and impact (severity of consequence to the organization, scale 1-5) to produce a risk score (1-25), categorized into Low / Medium / High / Critical bands.
- **Risk Register:** Consolidated asset-threat pairings into discrete risk statements, each scored and mapped to the primary NIST CSF function(s) it relates to.
- **Risk Treatment Plan:** For risks rated Medium and above, identified a treatment strategy (Mitigate, Transfer, Avoid, or Accept) and recommended controls mapped to specific NIST CSF subcategories, with assigned ownership and target timelines.

## 3.3 NIST CSF Function Overview

| CSF Function  | Purpose                                                                                                                |
|---------------|------------------------------------------------------------------------------------------------------------------------|
| Govern (GV)   | Establish and monitor the organization's cybersecurity risk management strategy, expectations, and policy.             |
| Identify (ID) | Develop organizational understanding of assets, business context, and cybersecurity risk to systems, people, and data. |
| Protect (PR)  | Implement safeguards (access control, awareness, data security, protective technology) to manage risk.                 |
| Detect (DE)   | Implement activities to identify the occurrence of a cybersecurity event in a timely manner.                           |
| Respond (RS)  | Take action regarding a detected cybersecurity incident to contain and mitigate impact.                                |
| Recover (RC)  | Maintain plans for resilience and restore capabilities or services impaired by a cybersecurity incident.               |

## 4. Asset Inventory

The table below identifies the critical information assets in scope for this assessment. The Criticality (C-I-A) column reflects the organization's rating of Confidentiality, Integrity, and Availability impact (High / Medium / Low) should the asset be compromised.

| ID   | Asset Name                                            | Category                | Owner                  | Criticality (C-I-A) | Description / Notes                                                                         |
|------|-------------------------------------------------------|-------------------------|------------------------|---------------------|---------------------------------------------------------------------------------------------|
| A-01 | Patient Records Database (PostgreSQL)                 | Data / Information      | Database Admin Team    | H-H-H               | Stores PHI for ~120,000 patients; subject to HIPAA-equivalent data protection requirements. |
| A-02 | Hospital Information System (HIS) Application Servers | Application / Server    | IT Operations          | H-H-H               | Core clinical workflow application; 24x7 availability requirement.                          |
| A-03 | Active Directory Domain Controllers                   | Identity Infrastructure | IAM Team               | H-H-H               | Authentication and authorization for ~800 employees and service accounts.                   |
| A-04 | Email & Collaboration Platform (M365 tenant)          | Cloud Service           | IT Operations          | M-H-H               | Hosts corporate email, OneDrive, Teams; primary phishing attack surface.                    |
| A-05 | Endpoint Devices (laptops/desktops)                   | Hardware / Endpoint     | End User Computing     | M-M-M               | ~750 corporate-managed Windows endpoints; EDR agent deployed.                               |
| A-06 | Diagnostic Imaging Devices (PACS-connected)           | Medical / OT Device     | Biomedical Engineering | H-M-H               | Legacy imaging modalities with limited patching capability; network-segmented.              |
| A-07 | Cloud Infrastructure (AWS production VPC)             | Cloud Infrastructure    | Cloud Engineering      | H-H-H               | Hosts patient portal, billing API, and analytics workloads.                                 |
| A-08 | Billing & Payment Processing System                   | Application             | Finance IT             | H-H-M               | Processes card and insurance payment data; PCI-DSS scope.                                   |
| A-09 | VPN / Remote Access Gateway                           | Network Infrastructure  | Network Security       | H-M-H               | Remote access for ~150 remote/clinical staff; MFA-enforced.                                 |
| A-10 | SIEM Platform (ELK Stack)                             | Security Tooling        | SOC Team               | H-H-H               | Centralized log aggregation and detection; single point of monitoring.                      |
| A-11 | Backup & Disaster Recovery Storage                    | Data / Infrastructure   | IT Operations          | H-M-H               | Offsite + cloud backups for critical systems; tested quarterly.                             |
| A-12 | Third-Party Lab Results Integration (HL7 interface)   | Third-Party Integration | Integration Team       | M-H-H               | Inbound HL7 feeds from external diagnostic labs; trust boundary risk.                       |
| A-13 | Wi-Fi Network (Guest & Clinical SSIDs)                | Network Infrastructure  | Network Security       | M-M-M               | Segmented guest and clinical wireless networks across 6 facility sites.                     |

| ID   | Asset Name                                   | Category          | Owner       | Criticality (C-I-A) | Description / Notes                                             |
|------|----------------------------------------------|-------------------|-------------|---------------------|-----------------------------------------------------------------|
| A-14 | HR & Payroll System (SaaS)                   | Cloud Service     | HR / IT     | M-H-M               | Stores employee PII and bank details; vendor-hosted SaaS.       |
| A-15 | Source Code Repositories (GitHub Enterprise) | Application / Dev | Engineering | M-H-M               | Houses proprietary application code and CI/CD pipeline secrets. |

*Criticality ratings are determined by the asset owner in consultation with the GRC function, based on business impact analysis (BIA) outcomes.*

## 5. Threat Identification

The following threat scenarios were identified through a combination of threat intelligence review, MITRE ATT&CK technique mapping, vulnerability scan findings, and industry-sector threat landscape analysis (healthcare sector). Each threat event is mapped to the vulnerability it would exploit and the primary NIST CSF function(s) relevant to managing it.

| ID   | Threat Source                                    | Threat Event                                                                                      | Vulnerability Exploited                                                                        | NIST CSF Function(s)               |
|------|--------------------------------------------------|---------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|------------------------------------|
| T-01 | External — Cybercriminal (financially motivated) | Phishing email leads to credential theft and BEC/ransomware deployment.                           | Insufficient email filtering, low user awareness, lack of phishing-resistant MFA.              | Identify, Protect, Detect, Respond |
| T-02 | External — Ransomware Group                      | Ransomware encrypts HIS application servers and patient database, disrupting clinical operations. | Unpatched server vulnerabilities, flat network segmentation, weak endpoint detection coverage. | Protect, Detect, Respond, Recover  |
| T-03 | External — Opportunistic Attacker                | Exploitation of internet-facing AWS workload (e.g., misconfigured S3 bucket or exposed API).      | Cloud misconfiguration, missing CSPM controls, weak IAM role scoping.                          | Identify, Protect, Detect          |
| T-04 | Insider — Negligent Employee                     | Accidental exposure of patient data via misdirected email or unsecured file share.                | Lack of DLP controls, inadequate data handling training, excessive sharing permissions.        | Protect, Detect                    |
| T-05 | Insider — Malicious/Disgruntled Employee         | Unauthorized access to and exfiltration of patient records prior to departure.                    | Excessive standing privileges, lack of UEBA/anomaly detection, weak offboarding process.       | Identify, Protect, Detect, Respond |
| T-06 | External — Nation-State / Advanced Actor         | Supply-chain compromise via third-party HL7 lab integration leading to lateral movement.          | Insufficient third-party risk assessment, lack of network segmentation for integration points. | Identify, Protect, Detect, Respond |
| T-07 | External — Attacker (Network-based)              | Exploitation of legacy diagnostic imaging device (unpatched OS) to gain network foothold.         | End-of-life OT/medical device software, inadequate network segmentation/monitoring.            | Identify, Protect, Detect          |
| T-08 | Environmental — Natural/Utility                  | Power outage or data center failure causes extended downtime of production systems.               | Insufficient redundancy, untested DR/BCP procedures, single-region dependency.                 | Recover, Respond                   |
| T-09 | External — Credential Stuffing                   | Automated credential-stuffing attacks against VPN/remote access portal using leaked credentials.  | Password reuse, absence of breach-credential monitoring, account lockout gaps.                 | Protect, Detect                    |
| T-10 | External — Attacker (Web Application)            | SQL injection or broken access control on patient portal exposes patient database.                | Insecure coding practices, lack of WAF/SAST-DAST in CI/CD pipeline.                            | Identify, Protect, Detect, Respond |

| ID   | Threat Source                           | Threat Event                                                                          | Vulnerability Exploited                                                                               | NIST CSF Function(s)      |
|------|-----------------------------------------|---------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|---------------------------|
| T-11 | Insider — Third-Party Vendor/Contractor | Vendor with excessive remote access privileges introduces malware during maintenance. | Lack of vendor access governance, no just-in-time access, insufficient monitoring of vendor sessions. | Identify, Protect, Detect |
| T-12 | External — Wireless Attacker            | Rogue access point or Wi-Fi eavesdropping on clinical wireless network.               | Weak Wi-Fi segmentation, outdated WPA configuration, lack of wireless intrusion detection.            | Protect, Detect           |

## 6. Risk Rating Matrix

Risk is calculated as: Risk Score = Likelihood x Impact, with both factors rated on a scale of 1 (lowest) to 5 (highest). The resulting score (1-25) is categorized into four risk rating bands as shown below.

### 6.1 Likelihood and Impact Scales

| Rating                | Likelihood Definition (Probability of Occurrence)                                                                                                     |
|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 —<br>Rare           | Very unlikely to occur within the assessment period (less than once in 5 years).                                                                      |
| 2 —<br>Unlikely       | Could occur but not expected (once every 2-5 years).                                                                                                  |
| 3 —<br>Possible       | May occur at some point (within 1-2 years), consistent with sector threat trends.                                                                     |
| 4 —<br>Likely         | Expected to occur within the next 12 months based on current threat activity.                                                                         |
| 5 —<br>Almost Certain | Highly likely to occur, or already observed as an active/ongoing threat.                                                                              |
| Rating                | Impact Definition (Severity of Consequence)                                                                                                           |
| 1 —<br>Negligible     | Minimal operational, financial, reputational, or compliance impact; no patient/clinical impact.                                                       |
| 2 —<br>Minor          | Limited impact, contained to a single system or department; brief disruption.                                                                         |
| 3 —<br>Moderate       | Noticeable impact on operations or data; regulatory notification may be required.                                                                     |
| 4 —<br>Major          | Significant disruption to clinical/business operations, data breach involving PHI, or major regulatory/financial penalty.                             |
| 5 —<br>Severe         | Critical, organization-wide impact; potential patient safety risk, major data breach, prolonged outage, or existential financial/reputational damage. |

### 6.2 Risk Rating Matrix (5x5)

| Impact ↓ /<br>Likelihood → | 1 | 2  | 3  | 4  | 5  |
|----------------------------|---|----|----|----|----|
| 5                          | 5 | 10 | 15 | 20 | 25 |



|   |   |   |    |    |    |
|---|---|---|----|----|----|
| 4 | 4 | 8 | 12 | 16 | 20 |
| 3 | 3 | 6 | 9  | 12 | 15 |
| 2 | 2 | 4 | 6  | 8  | 10 |
| 1 | 1 | 2 | 3  | 4  | 5  |

| Score Range | Risk Rating | Treatment Priority                                            |
|-------------|-------------|---------------------------------------------------------------|
| 1 - 4       | Low         | Accept / monitor; address during routine review cycles.       |
| 5 - 9       | Medium      | Treat within 6-12 months; assign owner and monitor.           |
| 10 - 15     | High        | Treat within 3-6 months; report to management.                |
| 16 - 25     | Critical    | Immediate action (0-3 months); escalate to senior leadership. |

## 7. Risk Register

The risk register below consolidates each asset-threat pairing into a discrete risk statement, scored using the methodology in Section 6, and sorted by descending risk score (highest priority first).

| Risk ID | Risk Description (Asset + Threat)                                                                                   | Likelihood (1-5) | Impact (1-5) | Score | Rating   | Primary CSF Function(s)            |
|---------|---------------------------------------------------------------------------------------------------------------------|------------------|--------------|-------|----------|------------------------------------|
| R-02    | Phishing-driven credential compromise (T-01) leading to unauthorized access to Patient Records DB (A-01).           | 5                | 5            | 25    | Critical | Identify, Protect, Detect, Respond |
| R-01    | Ransomware deployment on HIS servers (A-02) via T-02, disrupting clinical operations and patient safety.            | 4                | 5            | 20    | Critical | Protect, Detect, Respond, Recover  |
| R-05    | Cloud misconfiguration in AWS production VPC (A-07) exposes billing data (A-08) (T-03).                             | 4                | 4            | 16    | Critical | Identify, Protect, Detect          |
| R-03    | SQL injection / access control flaw in patient portal (T-10) exposes Patient Records DB (A-01) via AWS prod (A-07). | 3                | 5            | 15    | High     | Identify, Protect, Detect          |
| R-06    | Supply-chain compromise via HL7 lab integration (A-12) enabling lateral movement (T-06).                            | 3                | 4            | 12    | High     | Identify, Protect, Detect, Respond |
| R-07    | Compromise of legacy diagnostic imaging device (A-06) used as network pivot point (T-07).                           | 3                | 4            | 12    | High     | Identify, Protect, Detect          |
| R-08    | Credential-stuffing attack against VPN gateway (A-09) results in unauthorized remote access (T-09).                 | 4                | 3            | 12    | High     | Protect, Detect                    |
| R-10    | Accidental data exposure via misdirected email or open file share containing PHI (A-01, A-04) (T-04).               | 4                | 3            | 12    | High     | Protect, Detect                    |
| R-04    | Malicious insider exfiltrates patient records (A-01) prior to offboarding (T-05).                                   | 2                | 5            | 10    | High     | Identify, Protect, Detect, Respond |
| R-09    | Extended outage of production data center / cloud region affecting A-02, A-07, A-11 (T-08).                         | 2                | 5            | 10    | High     | Respond, Recover                   |
| R-12    | Wireless eavesdropping or rogue AP on clinical Wi-Fi (A-13) intercepts unencrypted traffic (T-12).                  | 3                | 3            | 9     | Medium   | Protect, Detect                    |

| Ris<br>k ID      | Risk Description (Asset + Threat)                                                                             | Likelih<br>ood (1-<br>5) | Impact<br>(1-5) | Score    | Rating        | Primary CSF<br>Function(s) |
|------------------|---------------------------------------------------------------------------------------------------------------|--------------------------|-----------------|----------|---------------|----------------------------|
| <b>R-<br/>11</b> | Vendor/contractor with excessive privileged access introduces malware during maintenance (A-02, A-03) (T-11). | 2                        | 4               | <b>8</b> | <b>Medium</b> | Identify, Protect, Detect  |

## 8. Risk Treatment Plan

For all risks rated Medium and above, a treatment strategy and recommended set of controls have been defined below, mapped to specific NIST CSF v2.0 subcategories. All risks in this assessment have been assigned a 'Mitigate' treatment strategy, reflecting that the identified controls are cost-effective and operationally feasible relative to the residual risk reduction achieved. Rows are sorted by descending risk score (highest priority first).

| Risk ID | Treatment Strategy | Recommended Controls / Actions (mapped to NIST CSF)                                                                                                                                                                 | Target CSF Subcategories           | Owner                              | Target Timeline |
|---------|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------|------------------------------------|-----------------|
| R-02    | Mitigate           | Deploy phishing-resistant MFA (FIDO2) for all privileged and remote-access accounts; conduct quarterly phishing simulations; enable conditional access policies and impossible-travel alerting in M365.             | PR.AC-7, PR.AT-1, DE.CM-3          | IAM Team / SOC                     | 0-3 months      |
| R-01    | Mitigate           | Implement network segmentation (Zero Trust zones) isolating HIS servers; deploy EDR with ransomware behavior detection across all endpoints; validate offline/immutable backups via quarterly restore tests.        | PR.AC-5, PR.DS-1, DE.CM-1, RC.RP-1 | IT Operations / SOC                | 0-6 months      |
| R-05    | Mitigate           | Deploy Cloud Security Posture Management (CSPM) tooling for AWS production VPC; enforce least-privilege IAM roles via automated policy review; enable S3 bucket-level encryption and public-access blocks.          | ID.RA-1, PR.AC-4, PR.DS-1          | Cloud Engineering                  | 0-3 months      |
| R-03    | Mitigate           | Integrate SAST/DAST scanning into CI/CD pipeline; deploy WAF in front of patient portal; perform annual penetration test and remediate critical findings within 30 days.                                            | ID.RA-1, PR.IP-2, DE.CM-8          | Engineering / Security             | 0-3 months      |
| R-06    | Mitigate           | Conduct third-party risk assessments for all HL7 integration partners; place integration points in a dedicated DMZ segment with monitored traffic; require contractual security SLAs from lab partners.             | ID.SC-2, PR.AC-5, DE.CM-1          | Integration Team / GRC             | 3-6 months      |
| R-07    | Mitigate           | Establish dedicated VLAN for medical/OT devices with strict firewall rules; deploy passive network monitoring for anomalous device behavior; create compensating controls inventory for unpatchable legacy devices. | PR.AC-5, DE.CM-1, PR.IP-12         | Biomedical Eng. / Network Security | 3-6 months      |
| R-08    | Mitigate           | Enforce MFA on VPN gateway (already partially in place — extend to 100% coverage); integrate breach-credential monitoring feed to trigger forced password resets; tune lockout                                      | PR.AC-7, DE.CM-7                   | Network Security                   | 0-3 months      |

| Risk ID | Treatment Strategy | Recommended Controls / Actions (mapped to NIST CSF)                                                                                                                                       | Target CSF Subcategories  | Owner                  | Target Timeline |
|---------|--------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------|------------------------|-----------------|
|         |                    | thresholds.                                                                                                                                                                               |                           |                        |                 |
| R-10    | Mitigate           | Deploy Data Loss Prevention (DLP) policies across email and file-sharing platforms; provide role-based data-handling training; restrict default sharing permissions to internal-only.     | PR.DS-5, PR.AT-1          | IT Operations / GRC    | 3-6 months      |
| R-04    | Mitigate           | Implement least-privilege access reviews quarterly; deploy UEBA/anomaly detection for data access patterns; formalize and automate offboarding checklist with same-day access revocation. | PR.AC-1, PR.AC-4, DE.CM-3 | IAM Team / HR          | 0-6 months      |
| R-09    | Mitigate           | Update and test Business Continuity / Disaster Recovery plan with annual tabletop exercises; implement multi-AZ redundancy for critical workloads; document RTO/RPO targets per system.   | RC.RP-1, RC.IM-1, ID.BE-5 | IT Operations / GRC    | 3-9 months      |
| R-12    | Mitigate           | Migrate clinical Wi-Fi to WPA3-Enterprise with certificate-based authentication; deploy wireless intrusion detection (WIDS); conduct periodic rogue-AP sweeps across all sites.           | PR.AC-5, PR.PT-4, DE.CM-1 | Network Security       | 3-9 months      |
| R-11    | Mitigate           | Implement Privileged Access Management (PAM) with just-in-time vendor access and session recording; require vendor access requests to be approved and time-bound.                         | PR.AC-1, PR.AC-4, DE.CM-3 | IAM Team / Vendor Mgmt | 3-6 months      |

## 8.1 Residual Risk Statement

Upon successful implementation of the controls listed above, residual risk for each item is expected to fall by one to two rating bands (e.g., Critical to High, or High to Medium), primarily through reduction in likelihood rather than impact, as the underlying business and clinical context driving impact severity (e.g., presence of PHI, 24x7 operational requirements) cannot be eliminated. Residual risk should be formally re-assessed following control implementation and validated through testing (e.g., penetration testing, tabletop exercises, control effectiveness audits) before downgrading a risk's status in the register.

## 9. Governance, Roles & Review Cycle

### 9.1 Roles and Responsibilities

| Role                               | Responsibility                                                                                                                              |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| GRC / Risk Owner                   | Maintains the risk register, facilitates risk assessment workshops, tracks treatment plan progress, and reports risk posture to leadership. |
| Asset Owners                       | Validate asset inventory entries, criticality ratings, and confirm acceptance of residual risk for assets under their ownership.            |
| IT Operations / Security Teams     | Implement and operate technical controls identified in the treatment plan (e.g., EDR, segmentation, backups).                               |
| SOC / Detection Team               | Operate monitoring and detection controls; provide input on likelihood ratings based on observed threat activity.                           |
| Senior Leadership / Risk Committee | Review and approve risk acceptance decisions for High and Critical risks; allocate budget for treatment plan execution.                     |

### 9.2 Review and Update Cycle

- This risk assessment should be formally reviewed annually, or triggered earlier by: a significant security incident, major change to in-scope systems or architecture, new regulatory requirements, or material changes to the threat landscape (e.g., new CVEs affecting in-scope assets).
- The risk register should be updated on a rolling basis as treatment actions are completed, with residual risk re-scored and the risk rating matrix re-applied.
- Risks accepted without treatment (status: Accept) must be formally signed off by the relevant Asset Owner and recorded with a justification and review date.

### 9.3 NIST CSF Function Coverage Summary

The table below summarizes how the proposed treatment plan distributes control investment across the six NIST CSF v2.0 functions, providing a high-level view of program maturity focus areas.

| CSF Function  | Coverage in This Assessment                                                                                                                                           |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Govern (GV)   | Indirectly addressed through the risk register review cycle, role assignments, and management reporting structure defined in Section 9.                               |
| Identify (ID) | Asset inventory (Section 4), threat identification (Section 5), and third-party risk controls (R-06, R-11) directly support this function.                            |
| Protect (PR)  | The majority of treatment actions (MFA, segmentation, DLP, PAM, access reviews, encryption) fall under Protect — the largest area of control investment in this plan. |
| Detect (DE)   | EDR, UEBA, CSPM alerting, wireless intrusion detection, and SIEM-based monitoring (A-10) support detection capability across multiple risks.                          |
| Respond (RS)  | Incident response readiness is implicitly strengthened by detection improvements; a dedicated incident response plan review is recommended as a follow-on activity.   |

| CSF Function | Coverage in This Assessment                                                                                                                    |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| Recover (RC) | Backup validation, BCP/DR testing, and multi-AZ redundancy (R-09, R-01) directly support recovery capability for the highest-impact scenarios. |

*Recommended follow-on activity: develop a dedicated Incident Response Plan and conduct a tabletop exercise simulating the R-01 (ransomware) and R-02 (credential compromise) scenarios, to validate Respond function readiness not fully scoped in this assessment.*

---

*End of Document — NIST CSF Risk Assessment v1.0*